

Metodologías de gestión del riesgo: comparar, elegir y tratar

Del contexto al método

En la Lección 07 se definieron las reglas: alcance, escalas, tolerancias y propietarios. Con esas reglas todavía falta decidir **cómo** se hará el trabajo: qué pasos se siguen, en qué orden, qué produce cada paso y cada cuánto se repite.

¿Qué referencia ordena el trabajo de riesgo de esta organización, qué entrega cada etapa, y cómo se evita que el proceso termine el día en que se entrega una matriz?

Tres ideas ordenan la lección:

- una metodología se elige por **las decisiones que debe apoyar** y por la **capacidad** de quien la aplicará;
- las referencias no compiten: responden preguntas distintas y pueden **combinarse**, siempre con **una sola escala**;
- el riesgo se **trata**, no se elimina: siempre queda un residual que alguien con autoridad acepta.

1. Gestionar no es lo mismo que evaluar

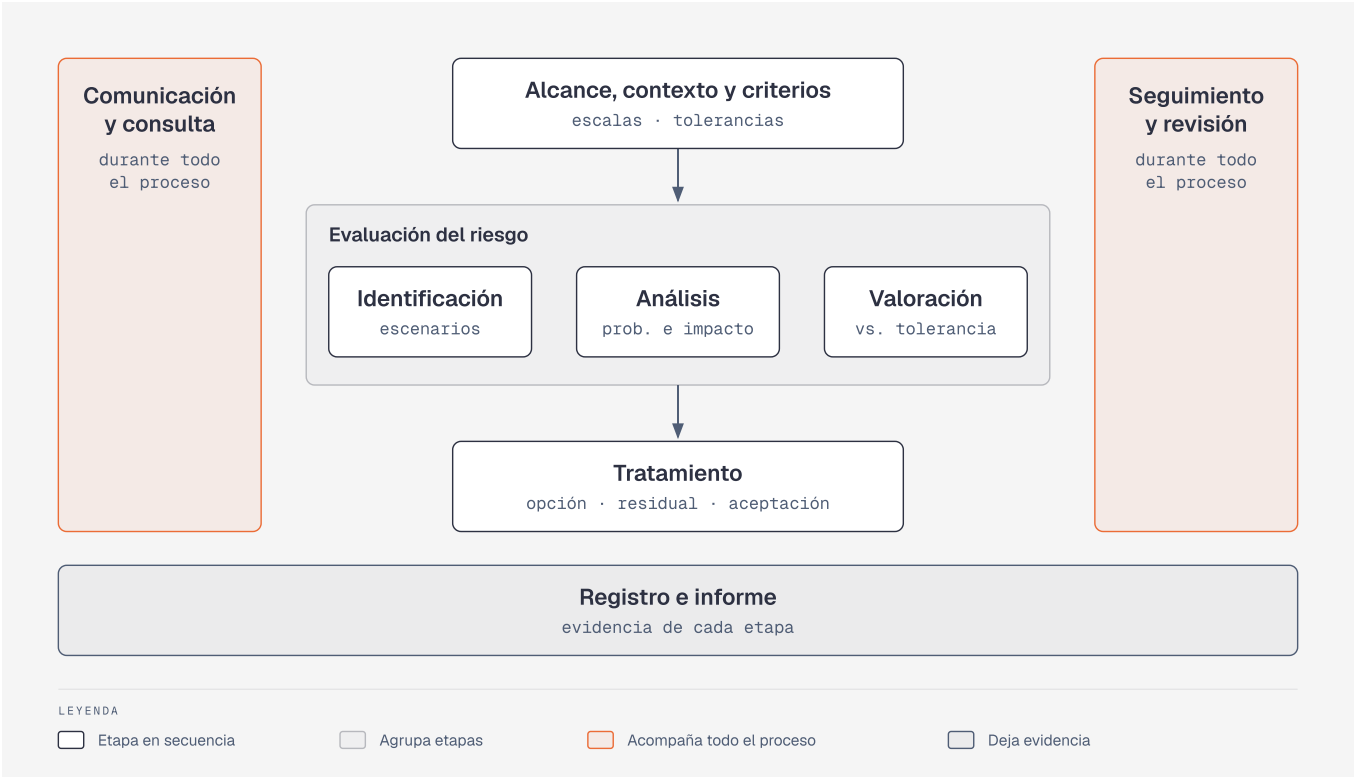
Concepto	Pregunta que responde	Duración
Gestión del riesgo	¿Cómo decide la organización, de forma continua, qué riesgos asume, cuáles trata y quién responde?	Permanente: forma parte de la operación
Evaluación del riesgo	¿Qué riesgos existen hoy, qué tan probables son y qué impacto tendrían?	Un ejercicio con fecha, que se repite
Tratamiento del riesgo	¿Qué se hará con cada riesgo evaluado?	Un plan con responsables y plazos

La evaluación es **una etapa** dentro de la gestión. Una organización que solo evalúa produce informes; una que gestiona toma decisiones, las registra, comprueba si funcionaron y vuelve a evaluar cuando algo cambia.

Esta distinción explica por qué las referencias parecen parecidas y no lo son: algunas describen el proceso completo de gestión, otras se concentran en cómo evaluar y otras en cómo expresar resultados.

2. El proceso común

La Lección 07 mostró que las metodologías difieren en el nombre de las etapas, no en su lógica. La norma ISO 31000:2018, aplicable a cualquier tipo de riesgo, describe ese proceso común:



Etap	Qué produce
Alcance, contexto y criterios	Qué se analiza, para qué objetivos, con qué escalas y tolerancias
Identificación	Lista de escenarios de riesgo: qué podría ocurrir, por qué y con qué consecuencia
Análisis	Probabilidad, impacto, controles existentes e incertidumbre de cada escenario
Valoración	Comparación con los criterios: qué supera la tolerancia y qué prioridad tiene
Tratamiento	Opción elegida, acciones, responsables, plazos y riesgo residual aceptado
Comunicación y consulta	Quién recibe qué información y a quién se consulta antes de decidir
Seguimiento y revisión	Indicadores, fechas de revisión y hechos que obligan a repetir el ciclo
Registro e informe	Evidencia de que cada etapa ocurrió

Las dos etapas que atraviesan todo el proceso son las que más se omiten. Sin ellas, el proceso se convierte en un documento que se archiva.

3. ISO/IEC 27005:2022

Qué es. Una guía para gestionar los riesgos de seguridad de la información dentro de un sistema de gestión de seguridad de la información (SGSI). Desarrolla lo que la norma certificable ISO/IEC 27001 exige en materia de riesgo, y sigue el proceso general de ISO 31000.

Cómo está organizada. Contexto; evaluación (identificación, análisis y valoración); tratamiento, que termina con la aceptación del plan y del riesgo residual; comunicación y consulta; seguimiento y revisión; y la información documentada que demuestra cada etapa.

Dos enfoques para identificar. La edición 2022 admite dos caminos:

Enfoque	Punto de partida	Útil cuando
Basado en eventos	Escenarios de alto nivel: qué eventos podrían afectar los objetivos	Se necesita una visión estratégica rápida o hay pocos datos de activos
Basado en activos	Inventario de activos, amenazas y vulnerabilidades de cada uno	Se necesita detalle técnico y se dispone de inventario

Fortalezas. Es flexible, se integra con un sistema de gestión y está pensada para repetirse. No impone escalas: la organización las define, como se hizo en la Lección 07.

Límites. Es una guía, no un procedimiento paso a paso: exige adaptación y criterio. Su texto completo es de pago. Por sí sola no entrega tablas de probabilidad o impacto listas para usar.

4. NIST SP 800-30 Rev. 1

Qué es. Una guía para **realizar evaluaciones de riesgo**. Forma parte de una familia: NIST SP 800-39 describe la gestión completa en cuatro componentes: enmarcar (*frame*), evaluar (*assess*), responder (*respond*) y supervisar (*monitor*). SP 800-30 desarrolla en detalle el componente «evaluar».

Cómo está organizada. Cuatro pasos:

Paso	Contenido
1. Preparar	Propósito, alcance, supuestos, restricciones, fuentes de información, modelo de riesgo y enfoque analítico
2. Realizar	Identificar fuentes de amenaza y eventos de amenaza; identificar vulnerabilidades y condiciones predisponentes; determinar probabilidad; determinar impacto; determinar el riesgo
3. Comunicar	Entregar los resultados a quienes deciden, con sus supuestos e incertidumbre
4. Mantener	Actualizar la evaluación cuando cambian el contexto, las amenazas o los sistemas

Niveles. Puede aplicarse a la organización completa, a un proceso de negocio o a un sistema de información.

Fortalezas. Es detallada y rigurosa. Sus anexos traen tablas de ejemplo con escalas de cinco niveles y descriptores. Distingue fuente de amenaza, evento, vulnerabilidad y condición predisponente, lo que evita escenarios vagos. Es gratuita.

Límites. Evalúa, pero no desarrolla el tratamiento ni el gobierno del riesgo. Aplicada completa exige datos y juicio experto para cada escenario, lo que puede superar la capacidad de un equipo pequeño.

5. NIST CSF 2.0 y la serie NIST IR 8286

El marco de ciberseguridad

Qué es. Una taxonomía de **resultados** de ciberseguridad, organizada en seis funciones: GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND y RECOVER, cada una dividida en categorías y subcategorías.

Cómo se usa. La organización describe su **perfil actual** (qué resultados logra hoy, con qué evidencia) y su **perfil objetivo** (cuáles quiere lograr y para cuándo). La distancia entre ambos se convierte en un plan de acción priorizado. Los **Tiers** o niveles de implementación, del 1 al 4, describen cuán formal y coordinada es la gestión.

Relación con el riesgo. La función GOVERN incluye la estrategia de gestión del riesgo; IDENTIFY incluye la evaluación de riesgos como resultado esperado. El marco dice **qué resultado** debe lograrse, por ejemplo «los riesgos se identifican y se registran», pero no dice **cómo** evaluarlos.

Fortalezas. Es un lenguaje común entre áreas técnicas y dirección. Es gratuito y tiene guías rápidas para organizaciones pequeñas.

Límites. No asigna probabilidades ni impactos; no reemplaza una evaluación por escenario. Un perfil sin evaluación de riesgos detrás es una lista de deseos.

La serie IR 8286

Los informes NIST IR 8286 explican cómo integrar el riesgo de ciberseguridad en la gestión del riesgo de toda la empresa. El IR 8286A, cuya revisión 1 se publicó en diciembre de 2025, describe cómo identificar y estimar riesgos y propone un **registro de riesgos de ciberseguridad** con campos estandarizados: escenario, categoría, probabilidad, impacto, exposición, tipo de respuesta, costo, propietario y estado. Ese registro es el formato que se usará en las lecciones 09 y 10.

6. Cualitativo, semicuantitativo y cuantitativo

Enfoque	Cómo expresa el riesgo	Ventaja	Riesgo del enfoque
Cualitativo	Etiquetas con descriptores: bajo, medio, alto	Rápido; no exige datos numéricos	Si los descriptores son vagos, cada persona interpreta distinto
Semicuantitativo	Números ordinales: niveles 1 a 5 o rangos 0 a 100	Permite ordenar y comunicar	Se tiende a operar con los números como si fueran cantidades
Cuantitativo	Montos y probabilidades: pérdida esperada en pesos al año	Comparable con otras inversiones	Exige datos que pocas organizaciones tienen; da falsa precisión si se inventan

La escala de la Lección 07 es semicuantitativa con descriptores observables: los niveles son números, pero cada uno está anclado a un hecho verificable. Existen metodologías cuantitativas específicas, como FAIR, que se mencionan como referencia y no se trabajan en el curso.

7. Una sola escala

Una de las reglas más importantes del proceso, y la que más se rompe en la práctica.

Por qué no se mezclan puntajes

Situación	Por qué el número no se puede comparar
Un informe dice «alto» y otro «8»	«Alto» no tiene descriptor; «8» proviene de otra escala
Un escáner informa CVSS 8,1	CVSS mide la severidad técnica de una vulnerabilidad, no el riesgo para una organización: no considera la probabilidad en ese entorno ni el impacto en sus objetivos
Una autoevaluación multiplica 4 por 2	Los niveles ordinales indican orden, no cantidad: un 4 no es el doble de un 2, y su producto no tiene unidad
Una encuesta indica 70 % de preocupación	Mide percepción de personas, no probabilidad de un evento

Promediar esos valores produce un número que parece objetivo y no significa nada. Peor: ordena los riesgos según quién los evaluó y con qué herramienta, no según su importancia.

Cómo se convierte un valor externo

- Se busca la **evidencia** detrás del número: cuántas veces ocurrió, cuánto costó, qué condición existe.
- Se lee esa evidencia contra los **descriptores** de la escala común.

3. Si falta la evidencia, se declara `no convertible` , el dato faltante y quién podría entregarlo.

Nunca se traduce un número a otro número por proporción: un 8,1 sobre 10 no es un 4 sobre 5.

8. Tratamiento del riesgo

Después de valorar, se decide qué hacer con cada riesgo que supera la tolerancia. Las referencias usan nombres distintos para las mismas cuatro opciones:

Opción	ISO/IEC 27005	NIST SP 800-39	Qué hace	Ejemplo
Evitar	Evitar	Evitar	Elimina la actividad o condición que origina el riesgo	Dejar de guardar una copia de datos que no se necesita
Modificar	Modificar	Mitigar	Reduce la probabilidad, el impacto o ambos mediante controles	Procedimiento de baja de cuentas en 24 horas
Compartir	Compartir	Compartir o transferir	Traslada parte de la consecuencia a un tercero	Seguro, contrato con cláusula de responsabilidad
Retener	Retener	Aceptar	Asume el riesgo de forma informada, sin acciones adicionales	Retraso tolerable en un informe interno

El riesgo residual

Ninguna opción deja el riesgo en cero:

- **evitar** elimina ese riesgo, pero puede quitar un beneficio o crear otro riesgo;
- **modificar** reduce el riesgo, pero el control puede fallar o no cubrir todos los casos;
- **compartir** traslada parte de la consecuencia financiera, pero no la obligación legal ni el daño a la reputación;
- **retener** deja el riesgo igual; solo es válido si está dentro de la tolerancia.

El **riesgo residual** es el que queda después del tratamiento. Debe estimarse con la misma escala y **aceptarse formalmente** por quien tiene autoridad sobre el proceso afectado. Aceptar no es resignarse: es una decisión registrada, con fecha y responsable, que se revisa.

Seguimiento

Seguir un riesgo no es una quinta opción de tratamiento: es lo que se hace con **todos** los riesgos, tratados o no. Cada uno tiene un indicador, una fecha de revisión y un hecho que obliga a revisarlo antes de esa fecha.

Plan de tratamiento

Campo	Contenido
Riesgo	Identificador del registro
Opción	Evitar, modificar, compartir o retener
Acción	Qué se hará concretamente
Responsable	Quién ejecuta
Plazo	Fecha comprometida
Costo	Estimación y fuente del presupuesto
Evidencia de cierre	Qué demostrará que la acción se completó
Residual esperado	Nivel estimado después del tratamiento
Aceptación	Quién acepta el residual y cuándo

Este plan se construye en la Lección 10.

9. Cómo elegir una metodología

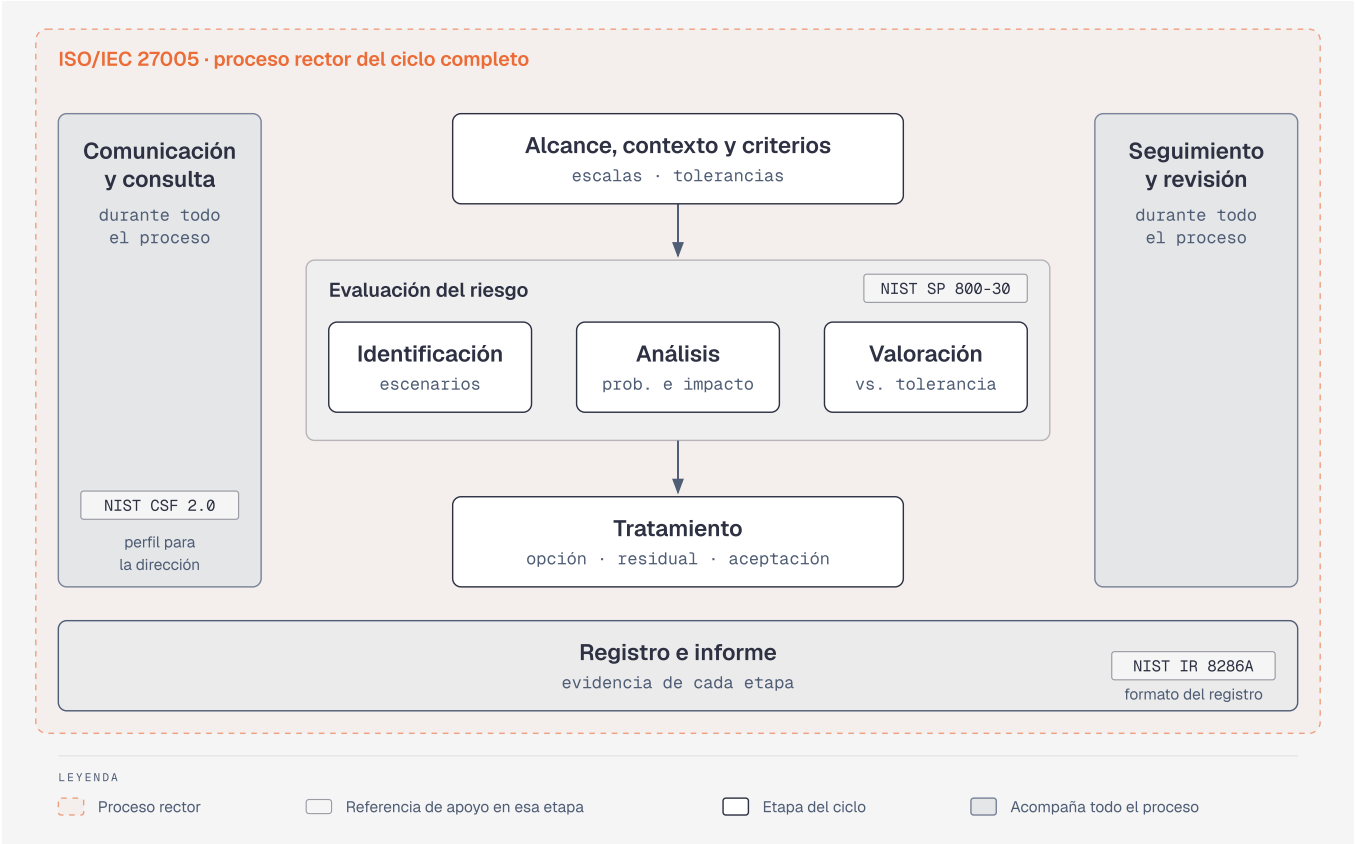
No existe «la mejor» metodología. Existe la más adecuada para una organización, una decisión y un momento.

Criterio	Pregunta
Decisión	¿Qué decisión debe apoyar el resultado: priorizar gasto, comunicar a la dirección, cumplir un requisito?
Capacidad	¿Cuántas personas y cuánto tiempo hay para aplicarla y repetirla?
Datos	¿Existen registros de frecuencia e impacto, o solo juicio experto?

Criterio	Pregunta
Sistema de gestión	¿La organización tiene o quiere un SGSI al que integrar el proceso?
Destinatario	¿Quién leerá los resultados: dirección, auditoría, equipo técnico?
Obligaciones	¿Algún contrato o norma exige una referencia concreta?

Combinar sin duplicar

Una combinación frecuente y defendible:



Las cuatro referencias trabajan con **una sola escala**, la que definió la organización.

Una organización pequeña puede usar un proceso simplificado de ISO/IEC 27005 como rector y aplicar SP 800-30 solo a los escenarios prioritarios. El paso «mantener» de SP 800-30 actualiza la **evaluación**; no sustituye el tratamiento, la aceptación ni el seguimiento del proceso completo. CSF puede comunicar resultados mediante un perfil reducido. No hace falta aplicar las tres referencias completas ni adoptar más de una escala.

10. Evidencias del proceso

Cada etapa debe dejar un artefacto que otra persona pueda revisar:

Etapas	Artefactos
Contexto y criterios	Ficha de alcance, escalas y tolerancias aprobadas
Identificación	Inventario de activos y lista de escenarios
Análisis	Registro con probabilidad, impacto, controles existentes, supuestos e incertidumbre
Valoración	Matriz o ranking con la regla de decisión aplicada
Tratamiento	Plan de tratamiento y actas de aceptación del residual
Comunicación	Informe a la dirección y registro de consultas
Seguimiento	Indicadores, actas de revisión y cambios registrados

Un ciclo se actualiza por **frecuencia** (por ejemplo, anual) y por **disparadores**: un incidente que supera una tolerancia, un cambio de proveedor, un sistema nuevo, una ley que entra en vigencia.

11. Errores frecuentes

Error	Por qué ocurre	Corrección
Elegir la norma más conocida	Se confunde prestigio con ajuste	Partir de las decisiones y la capacidad
Tratar CSF como evaluación de riesgos	Contiene la palabra riesgo	CSF describe resultados; la evaluación se hace con otro método

Error	Por qué ocurre	Corrección
Aplicar tres referencias completas	Se busca exhaustividad	Un rector y complementos acotados
Ordenar riesgos por CVSS	El puntaje es numérico y está disponible	CVSS es severidad técnica; el riesgo exige contexto
Promediar escalas distintas	Se quiere un número único	Convertir con evidencia a una sola escala
Declarar «riesgo eliminado»	Se confunde tratamiento con solución	Estimar y aceptar el residual
Considerar el seguro como solución completa	Se piensa solo en dinero	El seguro no traslada la obligación ni la reputación
Aceptar un incumplimiento legal	Se trata la ley como un riesgo más	Los requisitos se cumplen; el análisis decide cómo
Terminar el ciclo en la matriz	La matriz parece el producto final	Definir seguimiento, revisión y disparadores
No asignar quién acepta	Se supone que lo hará seguridad	Acepta quien tiene autoridad sobre el proceso

12. Ejemplo resuelto - caso VIÑA DEL ESTE (ficticio)

La empresa logística de la Lección 07, con 60 personas y una sola persona de TI con funciones de seguridad, ya definió su contexto. Ahora recibe tres pedidos: su cliente principal exige evidencia anual de gestión de riesgos para renovar la certificación; la gerencia quiere saber en qué invertir el presupuesto del próximo año; y el directorio pide una visión simple de dónde está la empresa.

Selección

Proceso rector:	ISO/IEC 27005 simplificada al alcance de despacho; ordena el ciclo, el tratamiento, la aceptación y la revisión, sin implantar un SGSI completo.
Evaluación:	NIST SP 800-30 solo para los escenarios prioritarios, porque existen registros de interrupciones que ayudan a estimar probabilidad.
Comunicación:	NIST CSF 2.0, perfil actual y objetivo de seis categorías.
Qué no se toma:	no se construye un perfil completo ni se adopta otra escala; la evaluación alimenta el perfil.
Escala:	la definida en la Lección 07.
Limitación:	el cliente podría exigir más evidencia anual que la producida por este alcance reducido; se verificará en el contrato.

Ciclo

Etap	Artefacto	Responsable	Se actualiza
Contexto	Ficha de contexto y escalas	Gerencia de operaciones	Anual o ante un cliente nuevo
Identificación y análisis	Registro de riesgos	Jefatura de tecnología	Anual o ante un incidente
Valoración	Ranking con regla de decisión	Gerencia de operaciones	Tras cada análisis
Tratamiento	Plan y aceptaciones	Propietarios de cada riesgo	Trimestral
Comunicación	Perfil para el directorio	Gerencia general	Semestral
Seguimiento	Indicadores y actas	Jefatura de tecnología	Mensual

Tratamiento de un escenario

Escenario:	interrupción del proveedor de rastreo satelital.
Opción:	compartir, mediante una cláusula de disponibilidad con penalización en el contrato de rastreo.
Residual:	la penalización compensa parte del costo, pero el despacho igual se interrumpe y el cliente igual se ve afectado.
Acepta:	gerencia de operaciones, porque decide sobre el proceso de despacho.
Complemento posible:	modificar, con un procedimiento manual de seguimiento de carga.

Conclusión de la etapa

VIÑA DEL ESTE sostendrá un ciclo simplificado de ISO/IEC 27005 y evaluará los escenarios prioritarios con NIST SP 800-30, porque necesita priorizar inversión y tiene datos de interrupciones. Comunicará al directorio un perfil reducido de CSF 2.0, con la misma escala. El ciclo tiene responsables y disparadores definidos. Todavía no se asigna ningún nivel de riesgo: eso ocurre durante el análisis.

13. Preparación para la actividad

Durante la práctica se continuará con PACÍFICO RETAIL. Conviene llegar con estas respuestas claras:

1. ¿Qué parte del proceso desarrolla NIST SP 800-30 y cuál deja a otras publicaciones?
2. ¿Qué entrega un perfil de CSF 2.0 y qué no entrega?
3. ¿Qué agrega ISO/IEC 27005 que no está en las otras dos referencias?
4. ¿Por qué un CVSS de 8,1 no equivale a un nivel 4 de probabilidad o impacto?
5. ¿Qué opción de tratamiento es un seguro y qué parte del riesgo no traslada?
6. ¿Quién puede aceptar un riesgo residual?

14. Glosario

Término	Definición
Aceptación del riesgo	Decisión registrada de asumir un riesgo residual, tomada por quien tiene autoridad.
Condición predisponente (<i>predisposing condition</i>)	Característica de la organización o del sistema que aumenta o reduce la probabilidad de que una amenaza tenga éxito.
CVSS	Sistema de puntaje de severidad técnica de vulnerabilidades, de 0 a 10.
Disparador de revisión	Hecho que obliga a repetir una etapa antes de su fecha programada.
Enfoque basado en activos	Identificación de riesgos a partir del inventario, sus amenazas y vulnerabilidades.
Enfoque basado en eventos	Identificación de riesgos a partir de escenarios de alto nivel sobre los objetivos.
Escala ordinal	Escala cuyos números indican orden, no cantidad.
Evaluación del riesgo	Identificación, análisis y valoración de los riesgos en un momento dado.
Gestión del riesgo	Actividades coordinadas y continuas para dirigir y controlar una organización respecto del riesgo.
Perfil (CSF)	Descripción de los resultados del marco que una organización logra o pretende lograr.
Plan de tratamiento	Documento con acciones, responsables, plazos, costos, evidencia y residual esperado.
Riesgo residual	Riesgo que permanece después del tratamiento.
SGSI (ISMS)	Sistema de gestión de seguridad de la información, según ISO/IEC 27001.

Fuentes

- [ISO 31000:2018 - Risk management guidelines](#). Proceso común de gestión del riesgo.
- [ISO/IEC 27005:2022 - Guidance on managing information security risks](#). Proceso de riesgo para un SGSI, enfoques de identificación y opciones de tratamiento.
- [ISO/IEC 27001:2022 - Information security management systems](#). Requisitos del SGSI que 27005 desarrolla.
- [NIST SP 800-30 Rev. 1 - Guide for Conducting Risk Assessments](#). Pasos, tareas y escalas de ejemplo para evaluar.
- [NIST SP 800-39 - Managing Information Security Risk](#). Enmarcar (*frame*), evaluar (*assess*), responder (*respond*) y supervisar (*monitor*).
- [NIST Cybersecurity Framework 2.0](#). Funciones, perfiles y *Tiers*.
- [NIST IR 8286 Rev. 1 - Integrating Cybersecurity and Enterprise Risk Management](#). Integración con la gestión del riesgo de la empresa.
- [NIST IR 8286A Rev. 1 - Identifying and Estimating Cybersecurity Risk for ERM](#). Escenarios, estimación y registro de riesgos.
- [FIRST - CVSS v3.1 Specification](#). Qué mide y qué no mide el puntaje CVSS.